

 PREMIER[®] POLICY	TITLE: Information Security Vulnerability Management Policy	
	DATE CREATED: 08/20/2020	VERSION NUMBER: 3
	DATE OF LAST REVIEW: 06/27/2022	DEPARTMENT OWNER: Information Security

Printed copies are for reference only. Please refer to the electronic copy for the latest version.

1. Purpose

To define requirements related to scanning, assessing and remediating security vulnerabilities.

2. Scope

Applies to information systems that reside within the Premier environment or systems that would be used to conduct or support the business of Premier. The requirements in this Policy include, but are not limited to, operating systems, applications, infrastructure components and middleware.

3. Definitions

Engineering Functions – Individuals and/or teams accountable for the day-to-day operations of an application, operating system, database, or infrastructure.

Patch – A patch is an additional piece of code developed to address a vulnerability in an existing piece of software.

Product Ownership Functions – Individuals and/or teams accountable for the product's success, vision, and strategic priorities.

Vulnerability – A weakness or control gap that, if exploited, could result in the unauthorized disclosure, misuse, alteration, loss of availability or destruction of information. It could be a flaw in the design or configuration of software that has security implications.

4. Attachments/References

Relevant Premier Enterprise Controls

[Premier Impact Assessment \(PIA\) Policy](#)

Security Exception Requests

[Premier Data Stewardship Program - Part IV Technical Safeguards Policies](#)

[Secure Development Lifecycle Policy](#)

POLICY

Vulnerability Scanning

1. Information Security is responsible for managing scanning systems and/or processes to identify application, operating system, database, and infrastructure vulnerabilities and/or non-compliant systems.

Vulnerability Assessment

2. Information Security and Engineering Functions are responsible for reviewing vulnerability scan results on a regular cadence. At a minimum, the review should include the following determinations and associated next steps.

Printed copies are for reference only. Please refer to the electronic copy for the latest version.

- 2.1 Applicability – If the vulnerability was misdiagnosed during scans and should be marked as “not applicable” within scanning system.
 - 2.1.1 If applicable, Engineering Functions should follow defined Information Security processes to have the misdiagnosed vulnerability reviewed.
- 2.2 Responsible Party – If Premier is able to remediate the vulnerability or if the vulnerability can only be remediated by a non-Premier entity.
 - 2.2.1 If applicable, Engineering Functions should follow defined Information Security processes to have the vulnerability tagged as third party.
- 2.3 Remediation Effort – If remediation is deemed a small, medium or large effort.
 - 2.3.1 Engineering Functions should utilize their remediation effort sizing, along with vulnerability rating, to determine if the vulnerability can be completed within the defined timeframe.

Vulnerability Remediation

- 3. Engineering Functions are responsible for remediating vulnerabilities within the defined timeframe. Vulnerabilities that cannot be remediated within the defined timeframe must be escalated to Portfolio Functions for prioritization.
- 4. Portfolio Functions are responsible for facilitating the review and prioritization of vulnerabilities that are escalated by Engineering Functions.
- 5. Vulnerabilities that are not remediated within the defined timeframe must be accounted for on Product Roadmaps or Backlogs. Delayed remediation, denoted by the placement of said remediation on a Product Roadmap or Backlog, is, by default, acceptance of the vulnerability's risk by Portfolio Functions.
- 6. When applying patches, the ITS Change Management and ITS Configuration Management Policies and Procedures must be adhered to.
- 7. Patches must be obtained from authorized sources.

Vulnerability Risk Ratings

- 8. Premier's Vulnerability Management Program utilizes a defined risk framework for rating vulnerabilities and patches. Raw scanning results, existing mitigating controls, and other factors are considered when assigning the Premier severity rating. Ratings are subjective due to the blend of vendor, third-party and Information Security assessments. Information Security utilizes the default severity ratings of third-party scanning tools but reserves the right to override this rating and determine the final rating. The defined ratings are as follows.
 - 8.1 Critical – Vulnerabilities that are exploitable and affect systems that process or store data subject to external regulatory requirements, or information classified as Premier Confidential, Personally Identifiable Information (PII) and/or electronic Protected Health Information (ePHI). Critical vulnerabilities are actively managed by Information Security.
 - 8.2 High – Vulnerabilities that are at a high likelihood of exploit and affect systems that process or store data subject to external regulatory requirements, or information classified as Premier Confidential, Personally Identifiable Information (PII) and/or electronic Protected Health Information (ePHI). High vulnerabilities are actively managed by Information Security.
 - 8.3 Medium – Vulnerabilities that are at a significant likelihood of exploit and affect any Premier systems. Medium vulnerabilities are managed at the discretion of Information Security.
 - 8.4 Low – Vulnerabilities that are at a low likelihood of exploit and affect any Premier systems. Low vulnerabilities are managed at the discretion of Information Security.

Printed copies are for reference only. Please refer to the electronic copy for the latest version.

Remediation Timeframes

9. Information Security is responsible for managing the defined remediation schedule and updating the timeframes as the process matures. Unless otherwise stated, the remediation timeframe begins on the date a mitigation and/or patch is available. The target timeframes are as follows.

Severity Rating	Target Remediation Timeframe
Critical	< 14 Calendar Days
High	< 45 Calendar Days
Medium	< 90 Calendar Days
Low	< 180 Calendar Days

10. Third party vulnerabilities that can't be patched by Premier are not subject to the above timeframes.

Where to Go with Questions and Concerns

Contact the Chief Information Security Officer (CISO) with questions or concerns about this Policy.